Quiz — SAML + OIDC

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

1. Why do short time windows, InResponseTo, and one-time assertion IDs exist — what attack do they blunt together?

2. Scenario: NotOnOrAfter is in the past but skew=300 and now is 60s past — accept or reject with skew=60? Why does skew exist at all?

3. Spot-the-bug: ACS URL checked with `startswith` instead of exact match. What fails and why?

4. Why is PKCE S256 a hash of the verifier (not the verifier itself on the wire) — what theft does that stop?

5. Why does the OAuth security BCP insist on exact redirect URI matching / issuer validation (name one mix-up mitigation)?

6. Why require `signed=True` in the kata's accept helper — what can an attacker do with an unsigned assertion?